# Stripe Webhook and Quantified Permissions

Transcript Analyzer · Hibah Nafees · 18 Oct 2026 · github.com/HibahNafees/transcript-analyzer · https://hibah-transcripts.vercel.app

## 1. The handler

`POST /stripe/webhook` (`app/Http/Controllers/StripeWebhookController.php`, about 80 lines):

- Verifies the `Stripe-Signature` header with Stripe's library (HMAC-SHA256 over the raw body). Rejects timestamps older than 5 minutes, and rejects everything if the signing secret is unset.
- Acts only on paid `checkout.session.completed` / `async_payment_succeeded` events and reads `metadata.order_id`.
- Sets `paid_at` once with `UPDATE orders … WHERE paid_at IS NULL`, so a duplicate or retried event can't change it or count the order twice.
- Bad signature: **400**, nothing changed. Every verified event, including ignored ones: **200**, so Stripe stops retrying.

## 2. Same event twice, bad signature once

Stripe sandbox (test mode), sent to the live endpoint through Vercel. Order 1 belongs to a dedicated test account.

| # | Sent | Response | Log line | orders.paid_at (order 1) |
|---|---|---|---|---|
| 1 | `stripe trigger checkout.session.completed` with metadata.order_id=1 (event evt_1URp7VEh0gYG3kQhC4ysObe5) | 200 | order 1 marked paid | NULL → 2026-10-18 08:07:06 |
| 2 | `stripe events resend` of the same event | 200 | order 1 already paid | unchanged, 08:07:06 |
| 3 | Same event body signed with a wrong secret | 400 Invalid signature | stripe.webhook.rejected: No signatures found matching the expected signature | unchanged, 08:07:06 |

**Boring all three times:** no 500 errors or stack traces, and exactly one paid order. The same cases plus a missing signature, a stale replay, an empty secret and ignored events are covered by `tests/Feature/StripeWebhookTest.php` (6 tests; the full suite is 38 tests, all passing).

## 3. Quantified permissions

| What gets consumed | Cap | Window | Enforced in |
|---|---|---|---|
| Fire API calls: 1 per speaker per analysis (upload or re-analyze) | 20 analyses per account | 1 hour, fixed window from the first hit | AppServiceProvider (RateLimiter 'fire') |
| Prompt / output size per Fire call | ≤ 24,000 chars in (≈6k tokens) / ≤ 700 tokens out | per call | TranscriptAnalyzer, FireClient |
| Time per Fire call / per upload request | 60 s / 180 s | per call / per request | FIRE_TIMEOUT, set_time_limit + nginx |
| Upload size | 4 MB .vtt | per request | TranscriptController (max:4096) |
| Log-in and sign-up attempts | 10 per IP | 1 minute | RateLimiter 'auth' |
| Account creation | needs INVITE_CODE (empty means closed) | none | RegisterController |
| Another user's transcripts | 0 (404) | none | TranscriptPolicy |
| orders.paid_at | set once per order | forever | StripeWebhookController |
| Webhook acceptance | 0 without a valid Stripe signature | signature ≤ 5 minutes old | Stripe Webhook::constructEvent |

**Worst case per account:** 20 analyses × ~7 speakers ≈ **140 Fire calls per hour**, each ≤ ~6k prompt + 700 output tokens.

## Not capped yet

- Speakers per transcript: one crafted 4 MB file with hundreds of speaker labels makes hundreds of Fire calls but counts as 1 of the 20. The next fix is a speaker cap (for example 60).
- Number of accounts: anyone with the invite code can sign up. Rotating INVITE_CODE closes it.
- Total Fire budget per day or across all accounts. The only global limit is the credit on the Fire key.
- Paid credits: orders.analysis_credits is recorded and marked paid, but uploads don't spend credits yet.